COMPTIA SECURITY+ SY0-701 DOMAIN 4 · SECURITY OPERATIONS (28%)

Security+ 4.5 · Secure Protocols

Mestre CyberSec · **Lesson 4.5 — Secure Protocols** (4:47) · Assistir Vídeo no YouTube ↗ · Treino Interativo: edusouzamarques.github.io/cybersec

Executive Lesson Summary: SEGURO: SSH 22, HTTPS 443, SFTP 22, SNMPv3, LDAPS 636, TLS 1.2/1.3, IPsec, WPA3. INSEGURO: Telnet 23, FTP 21, HTTP 80, SNMPv1/v2, LDAP 389, WEP/WPA, SMTP 25 sem TLS.

💡 Key Exam Highlights & Critical Concepts

- Portas seguras: SSH 22, HTTPS 443, SFTP, SNMPv3, LDAPS 636
- INSEGURAS (proibidas na prova): Telnet 23, FTP 21, HTTP 80, SNMPv1/v2

🎯 Exam Tips & Typical CompTIA Scenarios

- 'replaces telnet'=SSH (remote secure)

🧯 Beyond the Video: Official Exam Concepts, Protocols & Traps (Section 4.5 — Secure Protocols)

Why is this advanced coverage required for SY0-701?: Video lectures provide foundational concepts, but CompTIA tests practical engineering judgment and requires deep familiarity with the following protocols, acronyms, and operational nuances in this domain:

• Secure Shell (SSH)

Secure Shell (SSH) is a cryptographic protocol used for secure remote command-line access, tunneling, and file transfer over an untrusted network. It typically uses TCP port 22 and replaces insecure Telnet.

⚠ ***Exam Trap:*** *Se a prova disser 'substitui Telnet' ou 'remote seguro', marque SSH (porta 22). Não confunda com Telnet (23), que envia tudo em texto claro.*

• Hypertext Transfer Protocol Secure (HTTPS)

HTTPS is HTTP encapsulated within TLS, providing encrypted and integrity-protected web communication. It uses TCP port 443 and authenticates servers via certificates.

⚠ ***Exam Trap:*** *HTTPS = HTTP + TLS, porta 443. Se aparecer HTTP 80, é inseguro; a substituição segura é HTTPS 443.*

• Secure File Transfer Protocol (SFTP)

Secure File Transfer Protocol (SFTP) transfers files securely over an SSH session, providing encryption and authentication. It commonly uses TCP port 22, not the FTP ports 20/21.

⚠ ***Exam Trap:*** *SFTP não é FTP sobre TLS; ele roda sobre SSH na porta 22. FTP na porta 21 é inseguro e deve ser substituído.*

• Simple Network Management Protocol v3 (SNMPv3)

SNMPv3 is the secure version of SNMP that adds authentication and privacy (encryption) for network management. It replaces insecure SNMPv1 and SNMPv2c.

⚠ ***Exam Trap:*** *SNMPv3 = autenticação e criptografia (authPriv); SNMPv1/v2c usam community strings em texto claro. Portas comuns: UDP 161/162.*

• Lightweight Directory Access Protocol Secure (LDAPS)

LDAPS is LDAP over TLS/SSL, providing encrypted directory service queries and authentication. It typically uses TCP port 636, whereas LDAP uses plaintext port 389.

⚠ ***Exam Trap:*** *LDAP 389 é inseguro; LDAPS 636 é seguro. Se a questão pedir diretório criptografado, escolha LDAPS.*

• Transport Layer Security (TLS)

Transport Layer Security (TLS) is a cryptographic protocol that provides confidentiality and integrity for data in transit. Current secure versions are TLS 1.2 and TLS 1.3; SSL is deprecated.

⚠️ ***Exam Trap:*** *A prova considera TLS 1.2/1.3 seguro e SSL/antigas versões inseguras. HTTPS, LDAPS e SMTPS dependem de TLS.*

• Internet Protocol Security (IPsec)

IPsec is a suite of protocols that secures IP communications by authenticating and encrypting packets. It is used in VPNs and supports transport and tunnel modes.

⚠️ ***Exam Trap:*** *IPsec para VPN: ESP fornece criptografia; AH fornece autenticação/integridade. IKE usa UDP 500/4500 para negociação.*

• Wi-Fi Protected Access 3 (WPA3)

WPA3 is the latest Wi-Fi security standard, using Simultaneous Authentication of Equals (SAE) to improve password-based authentication and encryption. It replaces insecure WEP and WPA.

⚠️ ***Exam Trap:*** *WPA3 = SAE e forward secrecy; WEP/WPA são inseguros. Se perguntar melhor segurança wireless, escolha WPA3.*

🏛️ Conceptual Deep Dive, Real-World Analogies & GRC Analysis

📌 SSH & SFTP vs Telnet & FTP (Encrypted Remote Management & File Transfer)

🏠 **Real-World Analogy:** Using Telnet and plain FTP is like sending a postcard written in pencil with no envelope: every mail carrier and nosy bystander can read your credentials and files in cleartext. SSH (TCP port 22) and SFTP, by contrast, lock your communications inside an encrypted titanium strongbox before dispatch; only the legitimate recipient possessing the paired cryptographic private key can open it and execute commands or retrieve files.

🔍 **Root Cause & Background:** Legacy protocols were engineered for closed academic testbeds built on implicit trust. In today's threat landscape, cleartext transmissions allow any passive network sniffer or on-path attacker to harvest admin passwords in milliseconds.

🛡️ **GRC Auditor Perspective:** Auditing strict corporate bans against Telnet (port 23) and plain FTP (port 21); verifying firewall rules blocking these ports internally; and mandating public-key SSH authentication (Ed25519 or RSA 3072+) with root password login disabled.

⚠️ **How CompTIA Tests This:** Exam trigger: 'secure replacement for Telnet providing encrypted command-line access on TCP 22' = SSH. 'Secure file transfer running over SSH tunnel' = SFTP (port 22). Exam trap: FTPS uses TLS (ports 989/990), while SFTP operates over SSH (port 22).

📌 HTTPS & Transport Layer Security (TLS vs HTTP)

🏠 **Real-World Analogy:** Browsing over plaintext HTTP is like announcing your credit card number and banking PIN through a loudspeaker in a crowded train station. HTTPS (TCP 443 backed by TLS) is stepping into an armored, soundproof phone booth with mirrored glass that establishes an encrypted, private pipeline directly to the bank's vault, preventing eavesdropping and message alteration.

🔍 **Root Cause & Background:** Internet packets cross dozens of intermediary hops and public access points. Without cryptographic encapsulation, on-path adversaries can harvest unencrypted session cookies, inject malware, or alter transaction payloads.

🛡️ **GRC Auditor Perspective:** Enforcing mandatory HTTPS with HTTP Strict Transport Security (HSTS) headers enabled; disabling insecure cipher suites and deprecated protocols (SSLv3, TLS 1.0, TLS 1.1); permitting only TLS 1.2 and TLS 1.3.

⚠️ **How CompTIA Tests This:** Exam trigger: 'securing web traffic confidentiality and data integrity via TLS' = HTTPS (port 443). Threat trigger: 'forcing browser to downgrade connection from HTTPS to HTTP' = SSL Stripping (mitigated by HSTS).

📌 Network Tunnels & Secure Connectivity: IPsec (AH vs ESP)

🏠 **Real-World Analogy:** Connecting two branch offices across the public internet via IPsec is like boring a private underground security tunnel between two headquarters. In the IPsec protocol suite, 'AH' (Authentication Header) is the guard checking passenger badges and signing manifests, but the vehicle windows stay clear (no payload encryption). 'ESP' (Encapsulating Security Payload) is an armored truck with blacked-out ballistic glass: it delivers both origin authentication and complete payload confidentiality.

🔍 **Root Cause & Background:** Enterprises require authenticated, tamper-proof links between corporate headquarters and branch sites over untrusted public transit without paying for private dedicated circuits.

🛡️ **GRC Auditor Perspective:** Auditing site-to-site IPsec configurations: requiring ESP with AES-GCM 256 encryption; enforcing IKEv2 with robust Diffie-Hellman groups (DH Group 14+ or elliptic curves) to guarantee Perfect Forward Secrecy (PFS).

⚠️ **How CompTIA Tests This:** Exam trigger: 'IPsec protocol providing BOTH confidentiality (encryption) and data integrity/origin authentication' = ESP. 'IPsec protocol providing authentication and integrity WITHOUT payload encryption' = AH.

📌 Secure Network Infrastructure: DNSSEC, SNMPv3 & Authenticated NTP (NTS)

🏠 **Real-World Analogy:** DNSSEC is affixing a verifiable holographic notary seal on every page of a city telephone directory: you have ironclad cryptographic proof that the lookup record points to the real bank server and was not altered by a fraudster (defeating DNS cache poisoning). SNMPv3 in AuthPriv mode equips network administrators with encrypted military-grade radios, stopping eavesdroppers from intercepting metrics or injecting unauthorized shutdown signals. Authenticated NTP aligns every internal server clock to atomic time, preventing attackers from spoofing timestamps to validate expired certificates.

🔍 **Root Cause & Background:** Core network infrastructure protocols were implemented without cryptographic signing or authentication, rendering them vulnerable to cache poisoning, community string eavesdropping, and timestamp spoofing.

🛡️ **GRC Auditor Perspective:** Validating DNSSEC zone signing on public and internal domains; eliminating SNMPv1/SNMPv2c community strings in favor of SNMPv3 authPriv (SHA authentication + AES encryption); and configuring cryptographically authenticated NTP servers.

⚠️ **How CompTIA Tests This:** Exam trigger: 'cryptographically signs DNS resource records to prevent cache poisoning' = DNSSEC. Exam trigger: 'SNMP version that includes packet encryption and SHA authentication' = SNMPv3 authPriv.

⚡ QUICK-REFERENCE EXAM CHEAT SHEET

Typical Exam Scenario / Practical Situation	Technical Concept & Target Answer
Secure encrypted replacement for Telnet operating over TCP port 22 for remote system management	**SSH (Secure Shell)**
Secure file transfer protocol executing inside an encrypted SSH tunnel on TCP port 22	**SFTP (SSH File Transfer Protocol)**
IPsec protocol providing data integrity, origin authentication, AND payload encryption (confidentiality)	**ESP (Encapsulating Security Payload)**
Cryptographic signing of DNS resource records to defeat DNS cache poisoning and spoofing	**DNSSEC (DNS Security Extensions)**
Network monitoring protocol version adding cryptographic authentication and AES payload confidentiality	**SNMPv3 (authPriv)**
Security policy header commanding web browsers to connect strictly via HTTPS, mitigating SSL stripping	**HSTS (HTTP Strict Transport Security)**

✅ Authentic Practice Questions (10 Real Exam Scenarios)

Scenario-based exam questions. Complete explanations and distractor analysis are provided in the answer key below.

QUESTION 1 · EXAM SCENARIO

A network administrator at a manufacturing company currently manages core switches through a command-line session that transmits all keystrokes and credentials in cleartext. The company wants to keep remote CLI management but protect administrative credentials and configuration commands from packet capture. Which protocol should be implemented?

A) SNMPv3

B) HTTPS

C) SSH

D) SFTP

QUESTION 2 · EXAM SCENARIO

A retail company's customer portal is reachable at http://shop.example.com. During a review, auditors found that login credentials and session cookies can be intercepted on public Wi-Fi. The portal must keep using a browser but protect data in transit. Which protocol should be enabled?

A) HTTPS

B) SFTP to eliminate single points of operational failure

C) IPsec

D) LDAPS

QUESTION 3 · EXAM SCENARIO

A finance team exchanges large reports between an internal Linux server and a partner's server. The servers already have SSH keys configured for administration, and the team needs an encrypted file transfer method that uses those keys. Which protocol should be used?

A) FTP to eliminate single points of operational failure

B) SFTP

C) TFTP

D) SNMPv3

QUESTION 4 · EXAM SCENARIO

A network operations center monitors router uptime and interface utilization. The current monitoring system uses community strings and captures show that these strings and device details cross the network in cleartext. Management wants authentication and encryption for polling. Which version should be configured?

A) SNMPv1

B) SNMPv2c

C) LDAPS to enforce least privilege and reduce attack surfaces

D) SNMPv3

QUESTION 5 · EXAM SCENARIO

An HR application performs user lookups against Active Directory by sending simple bind credentials to a directory server. A security assessment found the credentials are readable on the internal network. The application can be updated to use a secure directory protocol. Which should be implemented?

A) LDAPS on 636

B) LDAP on 389 to enforce least privilege and reduce attack surfaces

C) SNMPv3 through automated configuration orchestration pipelines

D) SFTP while ensuring strict audit log retention compliance

QUESTION 6 · EXAM SCENARIO

A web server hosts an internal application. A scan shows it still accepts SSL 3.0, TLS 1.0, and TLS 1.1 in addition to TLS 1.2 and TLS 1.3. The security team wants to remove weak cryptographic protocols while keeping the application available over HTTPS. What should be done?

A) Enable WPA3 on the server to enforce least privilege and reduce attack surfaces

B) Require SNMPv3 for all web sessions through automated configuration orchestration pipelines

C) Disable SSL 3.0/TLS 1.0/1.1 and allow only TLS 1.2/1.3

D) Replace HTTPS with SFTP using standardized security content automation profiles

QUESTION 7 · EXAM SCENARIO

A company needs to connect two office networks over the internet. Traffic between the sites includes proprietary database replication that must be encrypted and authenticated at the network layer, transparent to applications. Which technology should be used?

A) HTTPS reverse proxy

B) SFTP while ensuring strict audit log retention compliance

C) LDAPS using standardized security content automation profiles

D) IPsec VPN

QUESTION 8 · EXAM SCENARIO

A corporate wireless network uses a single pre-shared key for all employees. A recent audit recommends a wireless security standard that provides stronger protection against offline dictionary attacks and forward secrecy. Which should be deployed?

A) WEP while ensuring strict audit log retention compliance

B) WPA3-Personal with SAE

C) WPA2-PSK to prevent unauthorized configuration drift across nodes

D) Open authentication with captive portal

QUESTION 9 · EXAM SCENARIO

A legacy internal inventory application only supports HTTP and cannot be modified. Remote administrators need to access its web interface securely from outside the office without exposing the HTTP port directly and without deploying a site-to-site VPN. Which approach should be used?

A) Configure an SSH tunnel to forward a local port to the application

B) Enable SNMPv3 on the application server to prevent unauthorized configuration drift across nodes

C) Use LDAPS for the web interface across all managed enterprise endpoints

D) Require WPA3 on the administrators' laptops while maintaining continuous telemetry and monitoring

QUESTION 10 · EXAM SCENARIO

An organization's mail server sends notification emails containing password reset links. A packet capture shows the SMTP session is not encrypted, and messages can be read in transit. The mail server should continue to send mail but protect message contents between servers. Which configuration should be implemented?

A) Continue using SMTP on port 25 without TLS to prevent unauthorized configuration drift across nodes

B) Configure IMAPS on port 993 for message transport

C) Enable SNMPv3 for mail server monitoring while maintaining continuous telemetry and monitoring

D) Enable TLS on the SMTP relay with STARTTLS or SMTPS

ANSWER KEY & COMPREHENSIVE DISTRACTOR EXPLANATIONS

Question 1: Option C — SSH

SSH provides encrypted remote terminal access and replaces cleartext Telnet. SNMPv3 is for monitoring and management data, not interactive CLI. HTTPS protects web management. SFTP is for file transfer.

Question 2: Option A — HTTPS

HTTPS uses TLS to encrypt HTTP traffic, including credentials and session cookies. SFTP is for file transfer, IPsec protects IP traffic at the network layer, and LDAPS is for directory queries.

Question 3: Option B — SFTP

SFTP runs over SSH port 22 and uses existing SSH credentials or keys. FTP and TFTP send data in cleartext; SNMPv3 is for monitoring.

Question 4: Option D — SNMPv3

SNMPv3 supports authentication and privacy, meaning encryption. SNMPv1 and SNMPv2c use cleartext community strings. LDAPS is a directory protocol, not monitoring.

Question 5: Option A — LDAPS on 636

LDAPS encrypts LDAP over TLS on port 636. LDAP on 389 is cleartext unless StartTLS is used. SNMPv3 and SFTP are not directory authentication protocols.

Question 6: Option C — Disable SSL 3.0/TLS 1.0/1.1 and allow only TLS 1.2/1.3

TLS 1.2 and TLS 1.3 are secure modern versions; legacy SSL and TLS versions are vulnerable. WPA3 is for wireless, SNMPv3 is for monitoring, and SFTP is for file transfer.

Question 7: Option D — IPsec VPN

IPsec protects IP traffic between gateways and is suitable for a site-to-site VPN. HTTPS protects web applications, SFTP transfers files, and LDAPS secures directory queries.

Question 8: Option B — WPA3-Personal with SAE

WPA3-Personal uses SAE, which mitigates offline dictionary attacks and provides forward secrecy. WEP and WPA2-PSK are weaker, and open authentication provides no encryption.

Question 9: Option A — Configure an SSH tunnel to forward a local port to the application

SSH port forwarding creates an encrypted tunnel for HTTP traffic. SNMPv3 is for monitoring, LDAPS is for directory services, and WPA3 only protects the wireless link.

Question 10: Option D — Enable TLS on the SMTP relay with STARTTLS or SMTPS

SMTP with TLS encrypts mail transport. SMTP on port 25 without TLS is cleartext. IMAPS is for retrieving messages, and SNMPv3 is for monitoring.